

SNI5GECT

A Practical Approach to Inject aNRchy into 5G NR

Luo, Garbelini, Chattopadhyay, Zhou · Singapore University of Technology and Design
USENIX Security 2025

The whole paper in one line

Every practical 5G attack used to require you to **become the network.**

SNI5GECT attacks the phone without ever pretending to be one.

BEFORE

Impersonator — build a rogue base station, lure the phone onto it

AFTER

Bystander — read the real conversation, slip one message in

The attack surface is a few milliseconds long

UE ↔ gNB (RAN) ↔ 5G Core

The attach procedure runs in two phases. SNI5GECT lives entirely in the first one.

PRE-AUTHENTICATION

Unencrypted by design

RRC Setup, Registration Request, Identity Request — sent in the clear before keys exist. Physical-layer signals are never encrypted at all.

This is not a bug. Bootstrap has to start somewhere.

POST-AUTHENTICATION

Encrypted, integrity-protected

Security context established. SNI5GECT cannot touch any of it.

The paper is explicit about this limit — it is a scope boundary, not a weakness they hid.

What was holding the field back

01

Rogue base stations are loud

A fake gNB must broadcast to attract the UE. Broadcasting is exactly what makes it detectable — and detectability is what makes rogue-BS attacks fragile outside a lab.

02

Rogue base stations are heavy

You synthesize an entire cell to deliver one malicious message. Enormous machinery for a small effect.

03

There was no passive alternative

The field lacked any tool to sniff live UE ↔ real-gNB traffic in real time. Without visibility, you cannot do anything subtler.

Sniff both directions, track the state, inject on cue

SNIFF

Decode uplink and downlink 5G NR messages in real time, as a silent third party. No transmission, nothing to detect.



TRACK

Reconstruct where the UE is in the attach handshake from the decoded messages. This is the hard part.



INJECT

Send a forged downlink message timed to the protocol state. The UE cannot tell it did not come from the real gNB.

The name is the architecture: sniff + 5G + inject.

Why "track the state" is the contribution

Spraying messages does not work

A protocol message is only plausible if it is the one the UE is currently waiting for. Out of sequence, it is discarded.

So you must know where you are

"The UE just sent a Registration Request, so it expects a reply right now" — that inference is what turns a sniffer into a weapon.

The design consequence

Uplink and downlink are decoded in parallel and fed into a single picture of connection state, which gates the injector. Passive observation is not the capability — passive observation plus correct timing is.

Three attack classes, escalating

One-shot

A single injected message, immediate effect

Malformed RRC Setup → crashes the UE modem.

Registration Reject → downgrades 5G to 4G.

One-shot with response

Inject, then harvest what comes back

Identity Request → UE replies with an Identity Response carrying its SUCI. Device fingerprinting.

Multi-stage

Sniff and inject across several states — the new result

Authentication replay downgrade. Disclosed to GSMA as CVD-2024-0096.

Note: the Registration Reject downgrade is borrowed from prior bidding-down work (TC11). The authentication replay is theirs.

DOES IT ACTUALLY WORK

Practical, in their sense of the word

80%+

sniffing accuracy,
uplink and downlink

70–90%

injection success at an
arbitrary protocol state

20 m

attacker-to-UE distance
still effective

5

commercial 5G handsets
tested

Tested against both srsRAN (open source) and Effnet (commercial) base stations — so the result is not an artifact of one permissive stack. Artifacts earned USENIX Available, Functional, and Reproduced badges.

THE TWIST WORTH NOTICING

The attack tool is also an instrument

Anything that can passively decode a live 5G link is a measurement platform, whichever direction you point it.

Offensive

Crash, fingerprint, downgrade

Measurement

Throughput and scheduling analysis by
reading DCI on a real link

Defensive

Generate PCAP datasets to train anomaly
detection on real 5G traffic

Modular by design, and open source — the authors frame reusability as a contribution, not an afterthought.

THE PATTERN ACROSS THIS COURSE

Every open interface is also an attack surface

RANBooster

Opening the fronthaul lets you splice in a middlebox — flexibility bought with a new insertion point.

SwapRAN

The base station becomes a program, so it inherits every problem software has, including patching it live.

SNI5GECT

The air interface bootstraps in the clear, so a bystander can read and write it. Same trade, one layer down.

The architecture is not a finished system to memorize. It is a platform — and every seam it opens for redesign, someone else can open for an attack.

What this opens up

Can the pre-auth window be protected at all?

You cannot encrypt the messages that negotiate encryption. So is the fix authenticating the bootstrap, or accepting it and detecting abuse?

Is injection detectable at the PHY?

The sniffer emits nothing, but the injector must transmit. Does that transmission leave a timing or power signature a gNB could learn?

Does this generalize?

Today: 5G, downlink only. The modular design invites uplink injection, LTE, and the same method against other pre-auth protocols.

Anomaly detection with real data

For the first time there is a way to capture live over-the-air 5G control traffic at scale. That is a dataset problem solved.

Takeaway

SNI5GECT does not break 5G cryptography.

It notices that a few milliseconds of every connection happen before the cryptography starts — and shows that is enough.

Questions